

DK WAVE TECHNOLOGY

Azure Administrator — Laboratoire Hands-On

RAPPORT D'ACTIVITÉ — PHASE 1

Mise en place des fondations

Identities • Groups of resources • RBAC • MFA • Governance

Rédacteur
Administrateur Azure

Statut
Phase 1 — Complétée ✓

Environnement
Microsoft Azure (West Europe)

1. Contexte de l'intervention

1.1 Présentation de l'entreprise

DK WAVE TECHNOLOGY est une entreprise éditrice de logiciels en pleine croissance. Elle compte 20 collaborateurs, opère une application SaaS web exposée à ses clients et dispose d'une main-d'œuvre majoritairement à distance. L'entreprise ne possède aucun centre de données sur site : la totalité de l'infrastructure est hébergée dans le cloud Microsoft Azure.

Effectif	20 collaborateurs, travail majoritairement à distance
Produit	Application SaaS web — exposition client directe
Environnements	Production / Développement-Test / Partagé (Shared)
Infrastructure	100 % cloud — aucun datacenter on-premise
Équipe IT	Un seul administrateur (rôle exercé dans ce laboratoire)
Conformité	Hygiène de sécurité de base requise dès le départ

1.2 Objectifs fixés pour la Phase 1

La Phase 1 constitue la fondation de l'ensemble du projet. Elle n'est pas une phase technique parmi d'autres : c'est le socle sur lequel reposent la sécurité, la gouvernance et l'organisation de tous les déploiements à venir. Les erreurs commises ici sont les plus coûteuses à corriger.

Principe directeur de la Phase 1

Cette phase est axée sur le contrôle, la sécurité et la discipline — pas sur la vitesse. Chaque décision prise ici a un impact durable sur l'ensemble du projet Azure.

À l'issue de cette phase, les livrables attendus étaient les suivants :

- Une structure d'abonnement Azure identifiée et documentée
- Des groupes de ressources créés selon une logique métier claire
- Un référentiel de tags permettant la gouvernance et le suivi des coûts
- Une plateforme d'identité Entra ID (Azure AD) opérationnelle
- Des utilisateurs et groupes de sécurité créés selon les rôles
- Des attributions RBAC appliquées selon le principe du moindre privilège
- Le MFA activé pour les comptes administrateurs via l'accès conditionnel

2. Travaux réalisés

2.1 Identification de l'abonnement Azure (Étape 1.1)

Ce qui a été fait

La première action a consisté à se connecter au portail Azure et à naviguer vers la section Subscriptions. Les informations essentielles ont été relevées : nom de l'abonnement, identifiant unique (Subscription ID) et type (Pay-As-You-Go / Student / Enterprise).

Pourquoi cette étape est fondamentale

Le périmètre RBAC commence au niveau de l'abonnement. Les politiques de gouvernance (Azure Policy) et les budgets s'y appliquent également. Dans un contexte multi-entreprise ou grands comptes, un administrateur peut jongler entre plusieurs abonnements : identifier avec certitude l'abonnement actif prévient les erreurs de déploiement critiques.

- L'ID d'abonnement a été copié et consigné dans un fichier de notes administrateur sécurisé, conformément aux bonnes pratiques terrain.

2.2 Création des groupes de ressources (Étapes 1.2 et 1.3)

Ce qui a été fait

Trois groupes de ressources ont été créés dans la région West Europe, correspondant aux trois domaines fonctionnels de DK WAVE TECHNOLOGY :

Groupe de ressources	Rôle et contenu attendu
rg-dkwave-shared	Services partagés : identité, réseau hub, supervision, sécurité (Firewall, Bastion, Log Analytics...)
rg-dkwave-prod	Toutes les ressources de l'environnement de production (VM, App Gateway, Load Balancer...)
rg-dkwave-nonprod	Environnements Dev et Test — budget maîtrisé, SLA allégé, isolation complète de la prod

Pourquoi cette organisation

- Contrôle du rayon d'impact : une erreur en production n'affecte pas les environnements de développement, et vice-versa.
- RBAC granulaire : les permissions peuvent être attribuées au niveau du groupe, ce qui évite une gestion utilisateur par utilisateur.
- Suivi des coûts par environnement : Cost Management peut filtrer les dépenses par groupe de ressources.
- Gestion du cycle de vie simplifiée : supprimer un groupe de ressources supprime l'ensemble de son contenu proprement.

2.3 Application des tags de gouvernance (Étape 1.4)

Ce qui a été fait

Un jeu de tags standardisé a été défini et appliqué à chaque groupe de ressources via le portail Azure. Les tags suivants constituent la base de la gouvernance :

Company	DK-WAVE
Environment	Prod / NonProd / Shared
Owner	IT
CostCenter	IT-OPS

Pourquoi les tags sont essentiels

Les tags ne sont pas optionnels dans un environnement d'entreprise. Ils sont la base de :

- La facturation et le suivi des coûts : Azure Cost Management filtre les dépenses par tag.
- L'automatisation : les scripts PowerShell et CLI ciblent les ressources via leurs tags (ex. AutoShutdown = True).
- La conformité : de nombreux frameworks réglementaires exigent une traçabilité des ressources.

2.4 Configuration d'Entra ID — Plateforme d'identité (Étape 1.5)

Ce qui a été fait

La plateforme d'identité Microsoft Entra ID (anciennement Azure Active Directory) a été vérifiée et initialisée : nom du tenant, domaine principal (*.onmicrosoft.com). L'ajout d'un domaine personnalisé dkwave.com a été envisagé comme étape optionnelle réaliste.

Pourquoi Entra ID est le premier composant à configurer

Toute authentification Azure transite par Entra ID. L'identité est le nouveau périmètre de sécurité. Sans une base d'identité solide, aucun contrôle d'accès n'est fiable.

2.5 Création des utilisateurs (Étape 1.6)

Ce qui a été fait

Trois comptes ont été créés pour simuler des rôles réels d'entreprise :

alice.admin@dkwave.com	Administratrice globale — gestion de l'ensemble de l'abonnement
bob.ops@dkwave.com	Opérateur Azure — exploitation quotidienne des ressources de production
svc-backup@dkwave.com	Compte de service — dédié aux opérations de sauvegarde automatisées

Pour chaque compte : mot de passe temporaire attribué et changement de mot de passe imposé à la première connexion.

Pourquoi les comptes de service méritent une attention particulière

Les comptes de service sont souvent sur-privilégiés et négligés dans les revues d'accès. Ils sont un vecteur d'attaque fréquent. La règle appliquée ici est claire : ne jamais utiliser un compte personnel pour les opérations automatisées (sauvegardes, CI/CD, scripts). Le compte svc-backup@dkwave.com dispose uniquement des permissions strictement nécessaires à son rôle.

2.6 Création des groupes de sécurité (Étape 1.7)

Ce qui a été fait

Trois groupes de sécurité ont été créés dans Entra ID, représentant les niveaux d'accès fonctionnels :

GRP-AZ-Admins	Accès administrateur complet — Alice assignée
GRP-AZ-Ops	Opérations quotidiennes — Bob assigné
GRP-AZ-Backup	Opérations de sauvegarde uniquement — svc-backup assigné

Principe clé : gérer les accès via des groupes, jamais directement

- Scalabilité : l'ajout d'un nouvel administrateur se fait en l'ajoutant au groupe, sans modifier les attributions RBAC.
- Auditabilité : les revues d'accès portent sur les groupes, ce qui réduit la complexité des audits.
- Indispensable en entreprise : les bonnes pratiques IAM interdisent les assignations RBAC directes aux utilisateurs.

2.7 Attribution des rôles RBAC (Étape 1.8)

Ce qui a été fait

Les rôles Azure ont été attribués aux groupes de sécurité avec un périmètre de portée précis, conformément au principe du moindre privilège :

Groupe	Rôle Azure	Périmètre
GRP-AZ-Admins	Owner	Abonnement / rg-dkwave-shared
GRP-AZ-Ops	Contributor	rg-dkwave-prod et rg-dkwave-nonprod
GRP-AZ-Backup	Backup Contributor	Abonnement entier

Pourquoi le RBAC est critique

- Il empêche les suppressions accidentelles de ressources par des comptes sans les bonnes permissions.
- Il réduit l'exposition aux risques : un compte compromis ne peut agir qu'à hauteur de ses permissions.
- Il est exigé lors des audits de sécurité et des certifications de conformité.

2.8 Activation du MFA et de l'accès conditionnel (Étapes 1.9 et 1.10)

Ce qui a été fait

Une politique d'accès conditionnel a été créée dans Microsoft Entra ID pour imposer le MFA à tous les membres du groupe GRP-AZ-Admins, sur toutes les applications cloud. Une seconde politique a été configurée pour bloquer les connexions jugées à risque (localisation hors des pays de confiance, appareil non conforme).

Impact sécurité du MFA

Selon les statistiques Microsoft, le MFA bloque 99 % des attaques basées sur le compromis d'identifiants. Dans un contexte où l'identité est le nouveau périmètre de sécurité, c'est la mesure défensive la plus rapide et la plus efficace à mettre en place.

Apport de l'accès conditionnel

L'accès conditionnel va au-delà du simple MFA : il implémente la logique Zero Trust. L'accès n'est accordé que si le contexte est jugé fiable (localisation, conformité de l'appareil, niveau de risque de la session). C'est un prérequis pour les organisations qui souhaitent se conformer aux frameworks de sécurité modernes.

3. Difficultés rencontrées

3.1 Compréhension du modèle d'abonnement

La distinction entre tenant, abonnement et groupe d'administration n'est pas immédiatement intuitive pour un administrateur débutant. Dans un compte de test ou étudiant, l'abonnement unique donne l'illusion d'une structure simple. En entreprise, il existe souvent plusieurs abonnements organisés sous des Management Groups, ce qui change la portée des RBAC et des politiques. Il a fallu bien cerner ce périmètre avant toute action.

3.2 Nommage des ressources et respect des conventions

Azure impose des contraintes de nommage strictes selon les types de ressources (longueur, caractères autorisés, unicité globale pour certains services). La mise en place d'une convention cohérente dès le départ — préfixe par type, suffixe par environnement — demande une réflexion préalable. Une ressource mal nommée ne peut souvent pas être renommée : elle doit être supprimée et recrée, ce qui peut entraîner des interruptions.

3.3 Propagation des attributions RBAC

Les attributions de rôles via Azure CLI nécessitent de récupérer l'Object ID des groupes Entra ID, et non leur nom affiché. Cette donnée n'est pas toujours visible directement dans l'interface. De plus, une attribution RBAC peut mettre quelques minutes à se propager, ce qui peut fausser les tests de validation immédiats et induire en erreur un administrateur inexpérimenté.

3.4 Configuration de l'accès conditionnel et risque de blocage

L'activation d'une politique d'accès conditionnel sur le groupe administrateur est une opération à risque : mal configurée, elle peut bloquer l'accès du seul compte administrateur disponible, rendant l'environnement inaccessible. La bonne pratique — et la difficulté rencontrée — est de tester la politique en mode "Report-only" avant de l'activer, et de toujours conserver un compte de secours (break-glass account) exclu de la politique.

3.5 Gestion des comptes de service et permissions minimales

Déterminer les permissions exactes dont un compte de service a besoin (sans lui en donner trop, sans lui en donner trop peu) est un exercice d'équilibre délicat. Le rôle "Backup Contributor" pour le compte svc-backup@dkwave.com a été identifié comme le périmètre correct, mais la tentation d'attribuer un rôle plus large pour aller plus vite est réelle. Ce point illustre l'importance de la discipline opérationnelle dès la Phase 1.

4. Validation et résultats

4.1 Checklist de validation

Critère de validation	Statut
Les trois groupes de ressources sont créés dans West Europe	VALIDÉ
Les tags de gouvernance sont appliqués sur chaque RG	VALIDÉ
Les utilisateurs peuvent se connecter à Azure Portal	VALIDÉ
Le MFA est imposé pour les membres de GRP-AZ-Admins	VALIDÉ
Le RBAC fonctionne : Bob ne peut pas supprimer rg-dkwave-shared	VALIDÉ
Les tags sont visibles dans Cost Management	VALIDÉ
Les groupes de sécurité contiennent les bons membres	VALIDÉ
svc-backup dispose uniquement du rôle Backup Contributor	VALIDÉ

4.2 Test de validation RBAC (scénario pratique)

Le test principal de cette phase consiste à vérifier que les permissions RBAC fonctionnent correctement dans un scénario réel :

Scénario de test — Bob tente de supprimer rg-dkwave-shared

Connecté en tant que bob.ops@dkwave.com (rôle Contributor sur les RG prod et nonprod uniquement), une tentative de suppression de rg-dkwave-shared doit échouer avec un message d'autorisation refusée. Résultat attendu : ÉCHEC. Résultat obtenu : ÉCHEC confirmé — RBAC correctement appliqué.

5. Bilan et enseignements

5.1 Ce que cette phase apporte au projet

La Phase 1 n'est pas visible des utilisateurs finaux. Elle ne déploie aucune application, aucun serveur web. Et pourtant, c'est elle qui détermine la solidité de l'ensemble. Une mauvaise structure d'abonnement, un RBAC mal pensé ou un tenant Entra ID mal configuré se paient tout au long du projet en refactoring coûteux, en incidents sécurité et en non-conformités lors des audits.

5.2 Compétences développées

- Maîtrise de la structure organisationnelle Azure (tenant, abonnement, groupes de ressources)
- Configuration opérationnelle d'Entra ID : utilisateurs, groupes, domaines
- Attribution RBAC avec portée granulaire selon le principe du moindre privilège
- Mise en place du MFA et de l'accès conditionnel via des politiques Entra ID
- Application d'une stratégie de gouvernance par tags dès la création des ressources
- Utilisation de l'Azure CLI pour des opérations reproductibles et auditable

5.3 Points de vigilance pour la suite

Les éléments suivants doivent rester constants dans les phases suivantes :

- Toute nouvelle ressource doit être déployée avec les tags définis en Phase 1.
- Toute nouvelle identité (utilisateur ou compte de service) doit être ajoutée à un groupe de sécurité et non dotée de RBAC direct.
- Le compte de secours (break-glass account) doit rester exclu des politiques d'accès conditionnel.
- Les Resource Locks seront ajoutés en Phase 3 pour protéger rg-dkwave-shared contre la suppression accidentelle.

Synthèse Phase 1

L'infrastructure d'identité et de gouvernance de DK WAVE TECHNOLOGY est opérationnelle. La base est sécurisée, organisée et auditable. Le projet peut avancer vers la Phase 2 : déploiement de l'infrastructure réseau et des machines virtuelles.

— Fin du rapport Phase 1 —